

① admin' * works because the ' closes the username field early, and * turns the rest of the SQL query into a comment so the database skips it and let us log in.

prepared state stops it because it separates executable code from user data.

② The HttpOnly part blocks javascript running in the browser from reading the cookie via document.cookie. So the theft is impossible.

③ (a) Browsers automatically attach stored login cookies to any request sent to the bank, even if triggered by attacker's site.

(b) CSRF token proves that the form submission has a secret, valid key from user's active session, where same site only checks where the request originated.

④ LLMs process user input and system instructions in the exact same text, so they can't tell them apart.

In direct injection, user types malicious commands straight into the chat. In indirect injection, the AI reads malicious commands planted inside external content.

⑤ * Least privilege - limit tool actions

* Human in the loop - Require a person to manually approve any refund before it processes.

* Input Validation - Enforce strict parameter checks before letting the tool run.

⑥

ZAP automatically scans app to find vulnerabilities, while Burp lets us manually intercept and manipulate requests.

⑦

Only test systems you own, or where a published bounty scope explicitly permits.